

SIMATS ENGINEERING

ASSESSMENT TOOL 3 – CASE STUDY

Course Code: ITA1407
Course Name: Ethical Hacking
Course Outcome: CO4
Assessment Weightage: 35%

Name: Priyadharshini M
Register Number: 192521051

QUESTION 1

E-Commerce Web Server Security Assessment Using Kali Linux

1. Introduction

A mid-sized e-commerce company hosts its web application on an Apache server running on Linux. Recently, customers have reported unauthorized transactions and abnormal account activities. The IT team has identified suspicious HTTP requests, attempts to access hidden directories, and attempts to inject malicious scripts into input fields. The server is also running an outdated version containing known vulnerabilities, and there is no Web Application Firewall (WAF).

This situation indicates that the web application and its supporting infrastructure may have multiple security weaknesses. A comprehensive security assessment should therefore examine the web server, application inputs, software versions, exposed resources, authentication mechanisms, and network-level protection.

2. Objectives of the Security Assessment

The main objectives are:

1. Identify exposed services and technologies.
2. Identify vulnerabilities in the Apache web server.
3. Detect hidden or unauthorized web resources.
4. Assess input-validation mechanisms.
5. Identify possible XSS and injection vulnerabilities.
6. Determine the effect of outdated software.
7. Evaluate the absence of WAF protection.
8. Recommend a layered security architecture.

3. Possible Attack Vectors

3.1 Outdated Apache Server

An outdated Apache version may contain publicly known vulnerabilities. Attackers can identify the server version and determine whether known vulnerabilities affect the system.

Possible consequences include:

- Unauthorized access
- Information disclosure
- Web-server compromise
- Service disruption

3.2 Hidden Directory Access

Attackers may attempt to discover directories that are not linked from the main website.

Examples include:

- /admin
- /backup
- /uploads
- Development directories
- Configuration locations

If sensitive files are exposed, attackers may obtain confidential information.

3.3 Input Validation Vulnerabilities

The application accepts user input through forms and parameters. If the application does not properly validate input, an attacker may submit specially crafted data.

Possible consequences include:

- XSS
- Injection attacks
- Application manipulation
- Unauthorized actions

3.4 Cross-Site Scripting

If user input is displayed without appropriate output encoding, malicious script content could execute in another user's browser.

In an e-commerce environment, this could potentially affect:

- Customer sessions

- Account information
- User trust
- Transaction security

3.5 Lack of Web Application Firewall

A WAF can provide an additional layer between clients and the web application. Without a WAF, malicious requests reach the application directly.

4. Reconnaissance

Reconnaissance is the first phase of penetration testing.

Passive Reconnaissance

The security analyst gathers information without unnecessarily interacting with the target.

Information may include:

- Domain information
- Public DNS information
- Technology stack
- Publicly exposed services
- Server information

Active Reconnaissance

In an authorized assessment, Kali Linux tools can be used to identify services.

Nmap

Nmap can identify:

- Open ports
- Running services
- Service versions

Example in an authorized laboratory:

```
nmap -sV <authorized-test-host>
```

The results help the tester understand the exposed attack surface.

5. Web Technology Identification

Tools such as **WhatWeb** can help identify technologies used by the website.

The tester may determine:

- Web server
- Framework
- Programming technology
- Web technologies
- Security-related headers

This information can be used to identify outdated or incorrectly configured components.

6. Vulnerability Scanning

Nikto

Nikto can be used in an authorized environment to identify common web-server issues.

It can help identify:

- Dangerous files
- Misconfigurations
- Outdated components
- Common server weaknesses

Example:

```
nikto -h http://<authorized-test-host>
```

Directory Enumeration

Tools such as Gobuster can be used to identify publicly accessible directories and resources during an authorized assessment.

The tester should document:

- Discovered resource
- HTTP response
- Security relevance
- Recommended action

7. Web Application Testing Using Burp Suite

Burp Suite can intercept and analyze HTTP requests and responses.

The tester should examine:

- GET and POST parameters

- Cookies
- Headers
- Authentication requests
- Session information
- Input fields
- Server responses

The purpose is to determine whether user-controlled input is handled securely.

8. Controlled Exploitation

Exploitation should only be performed after obtaining authorization.

The tester should:

1. Identify a suspected vulnerability.
2. Reproduce it using controlled test input.
3. Verify the server response.
4. Record evidence.
5. Determine the potential impact.
6. Avoid modifying real customer information.
7. Report the vulnerability and recommended fix.

The assessment should demonstrate the existence and impact of a vulnerability without causing unnecessary damage.

9. Impact Analysis

Security Area	Possible Impact
Confidentiality	Customer and account information may be exposed
Integrity	Unauthorized transactions or modification of data
Availability	Website or server may become unavailable
Authentication	Customer accounts may be compromised
Financial Impact	Unauthorized transactions and recovery costs
Reputation	Loss of customer trust

10. Layered Defense Strategy

A. Server Hardening

- Upgrade Apache and Linux components.
- Apply security patches regularly.

- Remove unnecessary services.
- Disable directory listing where unnecessary.
- Remove backup files from public directories.
- Apply least-privilege permissions.
- Restrict administrative interfaces.
- Enable HTTPS.

B. Secure Coding

- Validate all user input.
- Use appropriate allowlists.
- Apply context-sensitive output encoding.
- Implement secure session management.
- Use parameterized database queries.
- Perform regular code reviews.

C. WAF

A Web Application Firewall should be deployed to provide an additional layer of protection against common web attacks.

D. Network Security

- Use firewalls.
- Segment critical systems.
- Restrict administrative access.
- Deploy IDS/IPS where appropriate.
- Monitor network traffic.

E. Logging and Monitoring

Monitor:

- Suspicious HTTP requests
- Repeated login failures
- Directory enumeration
- Unusual transactions
- Administrative activity
- Server errors

11. Conclusion

The incident is the result of multiple weaknesses rather than a single problem. The outdated server, poor input validation, exposed resources, and absence of WAF protection increase the organization's attack surface. A defense-in-depth approach involving patch management, secure

coding, WAF deployment, network security, logging, monitoring, and regular penetration testing can significantly reduce the risk.

QUESTION 2

SQL Injection and Cross-Site Scripting Security Audit

1. Introduction

The financial services application allows users to log in, view account details, and perform transactions. A recent penetration test identified SQL Injection and Cross-Site Scripting vulnerabilities. Error messages expose database information, and user inputs are not properly sanitized. These weaknesses have resulted in sensitive customer data exposure and malicious scripts being injected into pages viewed by users.

Because financial applications process highly sensitive information, these vulnerabilities have serious confidentiality and integrity implications.

2. SQL Injection

SQL Injection occurs when untrusted user input is incorporated into SQL statements without appropriate parameterization or validation.

For example, an insecure application might construct a database query using user-controlled information:

```
SELECT account FROM users WHERE username = '<user_input>';
```

If the application directly combines input with SQL commands, an attacker may manipulate the intended database operation.

3. Possible Effects of SQL Injection

SQL Injection may potentially lead to:

- Unauthorized database access
- Exposure of customer records
- Modification of database information
- Authentication bypass in vulnerable implementations
- Loss of data integrity
- Application disruption

The exact impact depends on the application's database privileges and implementation.

4. SQL Injection Testing Methodology

Step 1 – Identify Input Points

The tester identifies parameters such as:

- Login fields
- Search fields
- Account identifiers
- URL parameters
- Form fields

Step 2 – Intercept Requests

Burp Suite is configured as a proxy between the browser and authorized test application.

The tester observes:

- Request parameters
- HTTP methods
- Cookies
- Headers
- Server responses

Step 3 – Send Request to Repeater

The request can be transferred to Burp Repeater for controlled testing.

Step 4 – Test Input Handling

The tester submits safe validation inputs and observes whether the application behaves unexpectedly.

Step 5 – Analyze Errors

Database errors may reveal that user input is reaching the database layer.

The security analyst should document:

- Error message
- Affected parameter
- Request
- Response
- Potential impact

5. SQLmap

SQLmap is a tool used to automate SQL Injection detection and validation in authorized environments.

A controlled example is:

```
sqlmap -u "http://<authorized-test-host>/page?id=1" --batch
```

SQLmap can help determine whether a parameter is potentially injectable.

It should only be used against systems explicitly included in the penetration-testing scope.

6. Cross-Site Scripting

Cross-Site Scripting, or XSS, occurs when an application processes attacker-controlled input in a way that causes it to execute as active content in another user's browser.

Types of XSS

1. Stored XSS

The malicious content is stored by the application and later displayed to users.

2. Reflected XSS

The malicious input is immediately reflected in the application's response.

3. DOM-Based XSS

The vulnerability occurs through unsafe client-side JavaScript processing.

7. XSS Testing Using Burp Suite

The security analyst should:

1. Identify input parameters.
2. Submit controlled test input.
3. Observe whether input is reflected.
4. Check whether special characters are properly encoded.
5. Determine whether the application treats input as data or executable content.
6. Identify the affected page and parameter.
7. Document the security impact.

Testing should use controlled proof-of-concept input and should not attempt to steal real customer credentials or session tokens.

8. CIA Triad Analysis

CIA Property	SQL Injection	XSS
Confidentiality	Sensitive database information may be exposed	User/session information may be exposed
Integrity	Database records may be modified	Web content may be manipulated
Availability	Database/application disruption may occur	Application functionality may be affected
Authentication	May contribute to authentication compromise	May target authenticated sessions
Trust	Financial data exposure damages customer confidence	Malicious content damages user trust

9. Mitigation Strategies

A. Input Validation

The application should validate:

- Type
- Length
- Format
- Allowed values

Validation should be implemented on the server side.

B. Parameterized Queries

Prepared statements and parameterized queries should be used instead of constructing SQL statements through string concatenation.

C. Output Encoding

User-controlled data should be encoded according to the context in which it is displayed.

D. Secure Error Handling

Production systems should avoid exposing:

- SQL statements
- Database names
- Table names
- Stack traces

- Internal file paths

E. Secure Session Handling

Implement:

- Secure cookies
- HttpOnly cookies
- Appropriate SameSite settings
- Session expiration
- Session invalidation
- Session regeneration after authentication

F. Additional Security Controls

- WAF
- Security headers
- Least-privilege database accounts
- Regular vulnerability assessments
- Secure coding practices
- Code reviews
- Security testing during development

10. Conclusion

SQL Injection and XSS are serious application-layer vulnerabilities. Burp Suite can assist with request and response analysis, while SQLmap can assist with authorized SQL Injection testing. The most effective defense is prevention through parameterized queries, input validation, output encoding, secure session management, proper error handling, and continuous security assessment.

QUESTION 3

Evil Twin Attack and Wireless Security Assessment

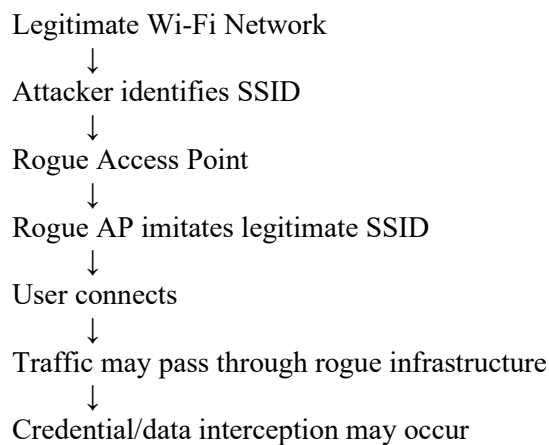
1. Introduction

The corporate office uses WPA2-PSK authentication for employee Wi-Fi. Employees report unusual login prompts and slow network performance. Investigation reveals a rogue access point using the same SSID as the legitimate network. The attacker uses this Evil Twin setup to capture credentials and perform man-in-the-middle activities.

2. What is an Evil Twin Attack?

An Evil Twin attack occurs when an attacker creates a rogue wireless access point that imitates a legitimate wireless network.

The basic attack flow is:



3. Attack Phases

Phase 1 – Wireless Reconnaissance

The attacker observes wireless information such as:

- SSID
- Channel
- Signal strength
- Security type
- Access-point characteristics

Phase 2 – Rogue Access Point

The attacker creates an AP designed to resemble the legitimate network.

Phase 3 – Victim Connection

A user may connect because the SSID appears familiar.

Phase 4 – Interception

Traffic passing through the rogue network may become observable or manipulable depending on the protocols and protections being used.

Phase 5 – Credential Collection

The attacker may present a fraudulent authentication page to trick users into submitting credentials.

4. Aircrack-ng

Aircrack-ng is a wireless security assessment suite.

In an authorized test environment, it can help security professionals:

- Discover wireless networks
- Monitor wireless traffic
- Analyze wireless security
- Assess wireless configuration

Its use in this case is to understand and detect wireless security weaknesses.

5. Wireshark

Wireshark is a packet-analysis tool that can be used to investigate suspicious network activity.

The analyst can inspect:

- Wireless management traffic
- Authentication activity
- Network traffic
- Unexpected gateways
- DNS behavior
- Unencrypted protocols

This can help determine whether traffic is passing through an unexpected wireless device.

6. Weaknesses in WPA2-PSK Configuration

Possible weaknesses include:

1. Shared password among employees.
2. Weak or reused PSK.
3. Lack of individual user authentication.

4. Lack of rogue-AP monitoring.
5. Users trusting familiar SSIDs.
6. Insufficient awareness of certificate/security warnings.

7. Countermeasures

A. WPA2-Enterprise / WPA3-Enterprise

Enterprise authentication can provide individual credentials and stronger centralized authentication.

B. Protected Authentication

Use appropriate certificate validation and secure authentication mechanisms to reduce the risk of fraudulent login portals.

C. Wireless Monitoring

Deploy Wireless Intrusion Detection/Prevention Systems.

They can help detect:

- Rogue APs
- Suspicious SSIDs
- Unexpected wireless devices
- Abnormal wireless behavior

D. Network Segmentation

Separate:

- Employee network
- Guest network
- Server network
- IoT devices

E. User Awareness

Employees should be trained to:

- Verify unexpected Wi-Fi networks.
- Avoid suspicious login pages.
- Report unusual Wi-Fi behavior.
- Never ignore certificate/security warnings.

8. Conclusion

The Evil Twin attack demonstrates that wireless security depends not only on encryption but also on authentication, monitoring, network architecture, and user awareness. Aircrack-ng and Wireshark can support authorized wireless security assessments. Strong enterprise authentication, rogue-AP detection, segmentation, and user training provide effective protection.

QUESTION 4

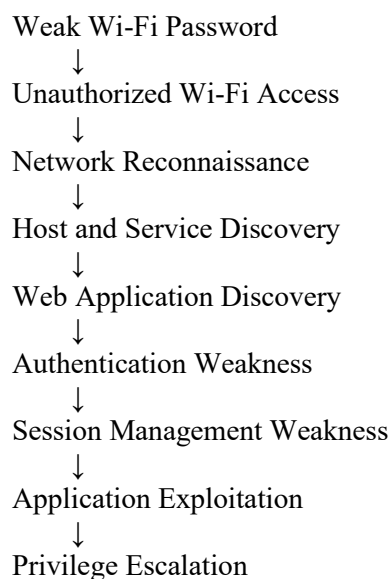
Full Penetration Testing Assessment – Wireless to Web Application

1. Introduction

The organization's internal network hosts a web-based employee management system that is accessible over Wi-Fi. The wireless network uses weak passwords, while the web application lacks proper authentication and session management. An attacker gains Wi-Fi access, performs reconnaissance, exploits application vulnerabilities, escalates privileges, and accesses confidential employee information.

This case demonstrates a chained attack in which weaknesses in different layers are combined.

2. Attack Chain



↓
Confidential Employee Data Access

3. Phase 1 – Wireless Security Assessment

The tester first assesses the wireless network.

Assessment Areas

- SSID configuration
- Encryption type
- Password strength
- Authentication mechanism
- Rogue devices
- Network segmentation

The objective is to determine whether unauthorized users can gain access to the internal network.

4. Phase 2 – Network Reconnaissance

Once authorized access to the test network is available, the tester identifies active hosts and services.

Nmap can be used for service discovery:

```
nmap -sV <authorized-test-host>
```

The results may identify:

- Web servers
- Database services
- Administrative services
- Service versions
- Open ports

5. Phase 3 – Web Application Enumeration

The tester identifies application components such as:

- Login page
- User-management functions

- Administrative pages
- Employee records
- APIs
- Session mechanisms
- Input forms

Burp Suite can be used to observe HTTP requests and responses.

6. Phase 4 – Authentication Testing

The tester evaluates:

Password Security

- Are weak passwords accepted?
- Is password policy enforced?
- Is account lockout implemented?

Authentication Mechanism

- Is authentication performed server-side?
- Can authentication be bypassed?
- Is MFA implemented where appropriate?

Password Recovery

The tester evaluates whether password-reset mechanisms are secure.

7. Phase 5 – Session Management Testing

The security analyst evaluates:

- Session-token generation
- Cookie security
- Session expiration
- Logout functionality
- Session invalidation
- Session fixation protection

A secure application should invalidate sessions appropriately after logout and sensitive authentication events.

8. Phase 6 – Authorization and Privilege Escalation

The tester checks whether users can access resources beyond their assigned roles.

For example:

Normal Employee
↓
Requests Admin Function
↓
Server checks role
↓
If unauthorized → Access Denied

The critical requirement is that authorization must be enforced by the server.

Hiding an administrative button in the user interface is not sufficient.

9. Phase 7 – Data Access Assessment

The tester determines whether an authorized low-privilege account can access confidential employee information belonging to another user.

Security controls should ensure:

- Users can access only permitted records.
- Administrative operations require appropriate privileges.
- APIs enforce authorization.
- Database queries respect user permissions.

10. Kali Linux Tools

Phase	Tool	Purpose
Wireless assessment	Aircrack-ng	Wireless security analysis
Network scanning	Nmap	Host/service discovery
Web assessment	Burp Suite	HTTP analysis
Web-server assessment	Nikto	Common web-server checks
Traffic analysis	Wireshark	Packet analysis
Vulnerability validation	Appropriate authorized tools	Controlled testing

11. Comprehensive Defense-in-Depth Framework

Wireless Layer

- WPA3 or WPA2-Enterprise
- Strong authentication
- Strong credentials
- Rogue-AP detection
- Wireless monitoring

Network Layer

- VLAN segmentation
- Firewalls
- IDS/IPS
- Network access control
- Restricted administrative access

Web Server Layer

- Regular patching
- Secure configuration
- Disable unnecessary services
- HTTPS
- Secure permissions

Application Layer

- Strong authentication
- Secure session management
- Input validation
- Output encoding
- Secure coding
- Server-side authorization

Database Layer

- Least privilege
- Strong database authentication
- Encryption
- Database activity monitoring
- Regular backups

Monitoring Layer

- Centralized logs

- SIEM
- IDS/IPS
- Security alerts
- Incident-response procedures

12. Conclusion

The attack chain begins with weak wireless security and progresses toward web-application exploitation and privilege escalation. This demonstrates that an organization's security cannot depend on a single layer. Wireless protection, network segmentation, secure authentication, secure sessions, strong authorization, server hardening, database security, and continuous monitoring must work together.

QUESTION 5

Wireless Deauthentication Attack Assessment

1. Introduction

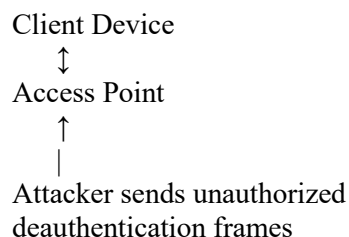
A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation shows repeated deauthentication attacks against access points. Automated deauthentication traffic continuously disconnects legitimate users, causing a denial-of-service condition.

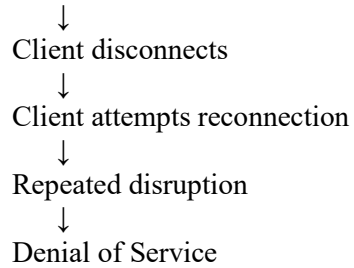
The major security objective is therefore to identify the cause, analyze the wireless protocol weakness, determine the effect on availability, and implement effective mitigation.

2. What is a Deauthentication Attack?

A deauthentication attack attempts to force wireless clients to disconnect from an access point by transmitting fraudulent or unauthorized deauthentication management frames.

Simplified process:





3. Protocol Weakness

Traditional wireless management-frame mechanisms historically provided limited protection against forged management frames.

An attacker can exploit this weakness by generating unauthorized deauthentication traffic.

Repeated attacks can cause:

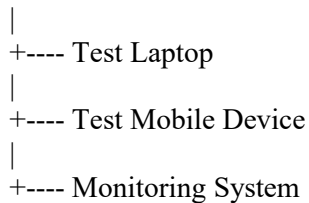
- Client disconnections
- Reconnection attempts
- Reduced network performance
- Loss of connectivity
- Reduced productivity

4. Controlled Simulation

Deauthentication testing should only be performed in an isolated and authorized laboratory.

Laboratory Setup

Test Access Point



The test environment should not affect university or public Wi-Fi users.

5. Testing Methodology

Step 1 – Identify the Test Network

Identify the authorized test access point.

Step 2 – Monitor Wireless Traffic

Use wireless analysis tools to observe normal traffic.

Step 3 – Establish Baseline

Record:

- Number of clients
- Normal connection rate
- Normal authentication activity
- Normal management traffic

Step 4 – Controlled Testing

Generate test traffic only within the isolated environment.

Step 5 – Packet Analysis

Use Wireshark to analyze management frames.

Step 6 – Compare Results

Compare normal and abnormal traffic patterns.

Step 7 – Document Findings

Record:

- Time of event
- Affected clients
- Number of suspicious frames
- Network impact
- Detection method
- Recommended mitigation

6. Wireshark Analysis

Wireshark can help identify abnormal patterns.

The analyst can inspect:

- Deauthentication frames
- Authentication frames
- Source and destination addresses
- Frequency of frames
- Timing patterns
- Client reconnection behavior

A sudden increase in deauthentication events can indicate a possible attack.

7. Impact on Network Availability

The attack primarily affects **Availability**.

Impact	Description
Students	Online classes may be interrupted
Faculty	Teaching and communication may be disrupted
Administration	Network-dependent operations may fail
Productivity	Users repeatedly reconnect
Applications	Network sessions may terminate
Support	Increased IT help-desk requests

8. CIA Triad Analysis

Confidentiality

Usually not the primary objective of a deauthentication attack.

Integrity

The attack does not primarily modify application data.

Availability

This is the primary target because legitimate users are prevented from maintaining network connectivity.

9. Countermeasures

A. Protected Management Frames

Deploy **Protected Management Frames (PMF / IEEE 802.11w)** where supported.

PMF helps protect management traffic against certain spoofing-based attacks.

B. Modern Wireless Security

Prefer modern wireless security such as WPA3 where supported.

C. Wireless IDS/IPS

A Wireless Intrusion Detection/Prevention System can identify unusual management traffic.

D. Network Monitoring

Monitor:

- Deauthentication rates
- Client disconnections
- Authentication failures
- Access-point health
- Rogue devices

E. Access Point Updates

Keep wireless controllers and access points updated with current security patches.

F. Network Redundancy

Where appropriate, provide overlapping wireless coverage and resilient network architecture so that disruption of one AP has less effect on users.

10. Incident Response

When repeated deauthentication attacks are detected:

1. Confirm the abnormal traffic.
2. Identify affected access points.
3. Collect wireless and system logs.
4. Capture relevant packet evidence.
5. Identify suspicious devices where possible.
6. Protect affected users.

7. Apply appropriate wireless security controls.
8. Monitor the network after remediation.
9. Document the incident.
10. Review security controls to prevent recurrence.

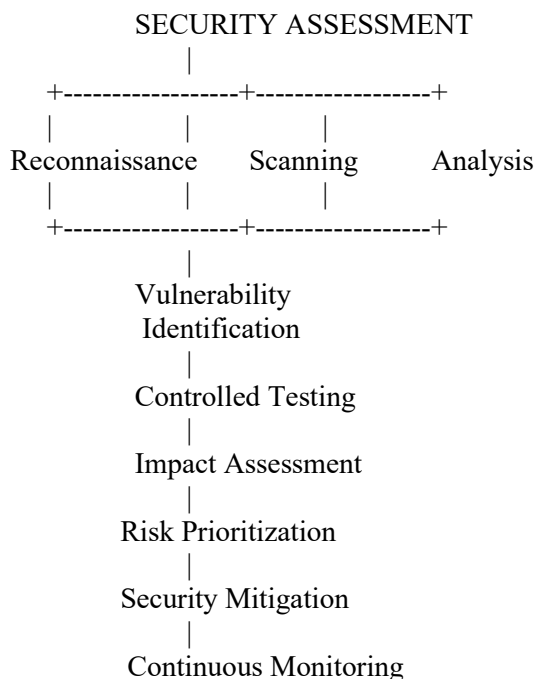
11. Conclusion

Deauthentication attacks exploit weaknesses in wireless management-frame security and primarily result in denial of service. Kali Linux wireless tools can support controlled security testing, while Wireshark can assist in packet-level analysis. Protected Management Frames, modern wireless protocols, wireless IDS/IPS, monitoring, patch management, and appropriate incident response can significantly reduce the impact of such attacks.

FINAL OVERALL CONCLUSION

The five case studies demonstrate the importance of a systematic ethical-hacking methodology.

The complete security assessment process can be represented as:



The major lessons from the assessment are:

1. **Web servers must be regularly patched and hardened.**
2. **Applications must validate input and encode output securely.**
3. **SQL Injection should be prevented through parameterized queries.**

4. **XSS should be prevented through secure input handling and output encoding.**
5. **Wireless networks should use strong authentication and modern security protocols.**
6. **Rogue access points require continuous wireless monitoring.**
7. **Authentication and session management must be securely implemented.**
8. **Authorization must be enforced on the server side.**
9. **Protected Management Frames can reduce certain wireless management-frame attacks.**
10. **Defense-in-depth is essential because attackers can combine weaknesses from different layers.**

Therefore, an effective cybersecurity program should combine **secure configuration, patch management, secure coding, strong authentication, network segmentation, monitoring, intrusion detection, user awareness, vulnerability assessment, penetration testing, and incident response.**